INFORME DE AUDITORÍA

Falta de atributos de seguridad (Secure y HttpOnly) en cookie de sesion cliente en "en.aegeanair.com"

OCTUBRE DE 2026

Índice / Tabla de Contenidos

1. Resumen Ejecutivo ..... Pág. 3
2. Detalles Tecnicos ..... Pág. 4
3. Gráficos de Distribución (Estado del Ticket) ..... Pág. 5
4. Prueba de Concepto ..... Pág. 6
5. Listado Resumido y Detalle de Hallazgos (1 tickets) ..... Pág. 7
6. Recomendaciones de Remediación ..... Pág. 8

Resumen Ejecutivo

Durante una revision de seguridad estrictamente pasiva sobre el dominio *en.aegeanair.com* de Aegean Airlines, se identifico una configuracion insegura en una de las cookies generadas por la aplicacion web.

Especificamente, la cookie denominada **ClientSession** (utilizada para mantener preferencias del lado del cliente) carece de los atributos de segridad **Secure** y **HttpOnly.** Esto significa que la cookie puede ser reenviada a traves de conexiones no cifradas y puede ser leida por scripts del lado del cliente. Si un atacante lograra interceptar el trafico de red de un usuario o explotar una vulnerabilidad XSS en el sitio, podria robar esta cookie.

Detalles Tecnicos

Activoafectado: https://en.aegeanair.com (en alcance según el programa de HackerOne).

Tipode vulnerabilidad: SecurityMisconfiguration(Configuraciónde seguridadincorrecta) / InformationDisclosure.

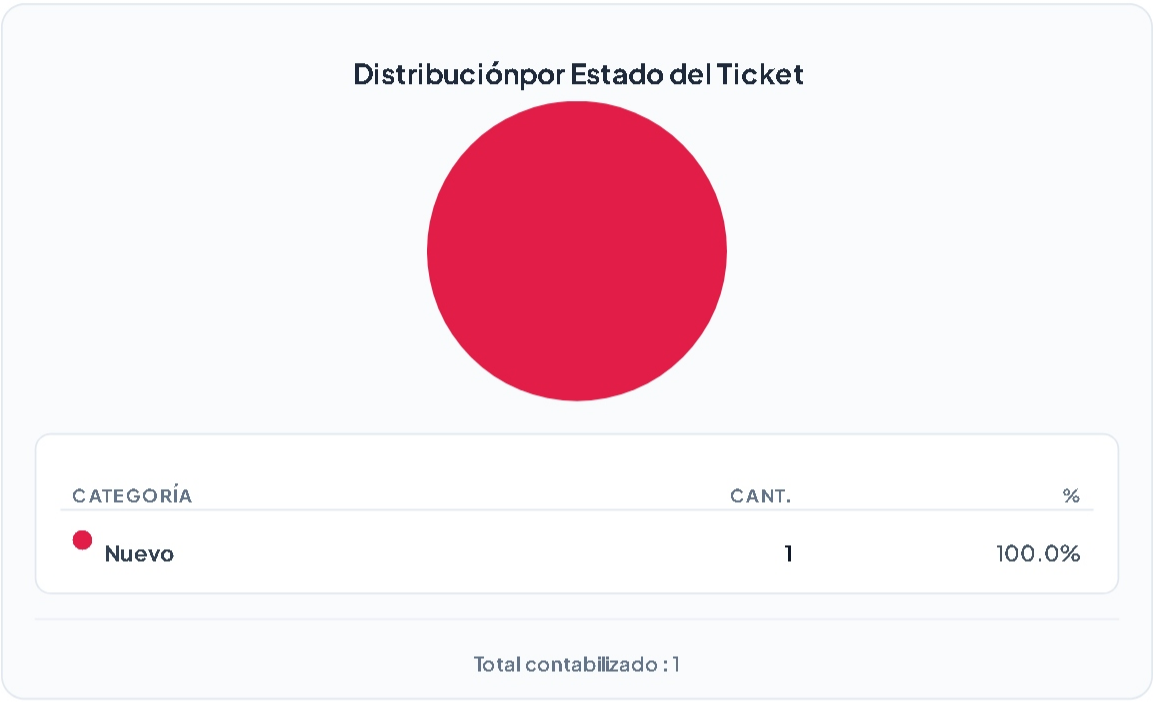
Cookie afectada: ClientSession(el nombre puede variar ligeramente, ej. ClientSes...).

Problemaidentificado:

Secure = false: La cookieno está restringidaa canales cifrados(HTTPS).

HttpOnly= false: La cookiees accesible a través de laAPI document.cookieen el navegador.

CVSS



CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N

Prueba de Concepto

Navegar a la página principal: https://en.aegeanair.com.

Abrir las herramientas de desarrollador (F12 o Clic Derecho > Inspeccionar).

Dirigirse a la pestaña "Almacenamiento" (Storage) y seleccionar "Cookies" en el menú izquierdo, haciendo clic en el dominio https://en.aegeanair.com.

En la tabla de cookies resultante, localizar la cookie de sesión de cliente (ClientSession o similar).

Observar las columnas de atributos de seguridad, donde se evidencia que HttpOnly está en false y Secure está en false.

HALLAZGO #1 Nuevo v1.0.0

Plantilla: NoobPlantilla
Ref ID: TCK-F6F027

TÍTULO

N/A (No Aplica)

RESUMEN EJECUTIVO

N/A (No Aplica)

DETALLES TECNICOS

N/A (No Aplica)

MÉTRICAS CVSS

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)

PRUEBA DE CONCEPTO (POC)

N/A (No Aplica)

RECOMENDACION DE REMEDIACIÓN

N/A (No Aplica)

Recomendaciones de Remediación

Para mitigar este hallazgo y alinearse con las mejores prácticas de seguridad, el equipo de desarrollo de Aegean Airlines debe configurar la cookie ClientSession con los siguientes atributos

Establecer Secure: Asegurar que la cookie solo se envíe a través de conexiones HTTPS. Esto protege la cookie contra la interceptación en texto plano en redes no seguras.

Establecer HttpOnly. Bloquear el acceso a la cookie a través de JavaScript (API del DOM). Esto mitiga drásticamente el riesgo de robo de sesión en caso de que se descubra una vulnerabilidad XSS en el sitio web.